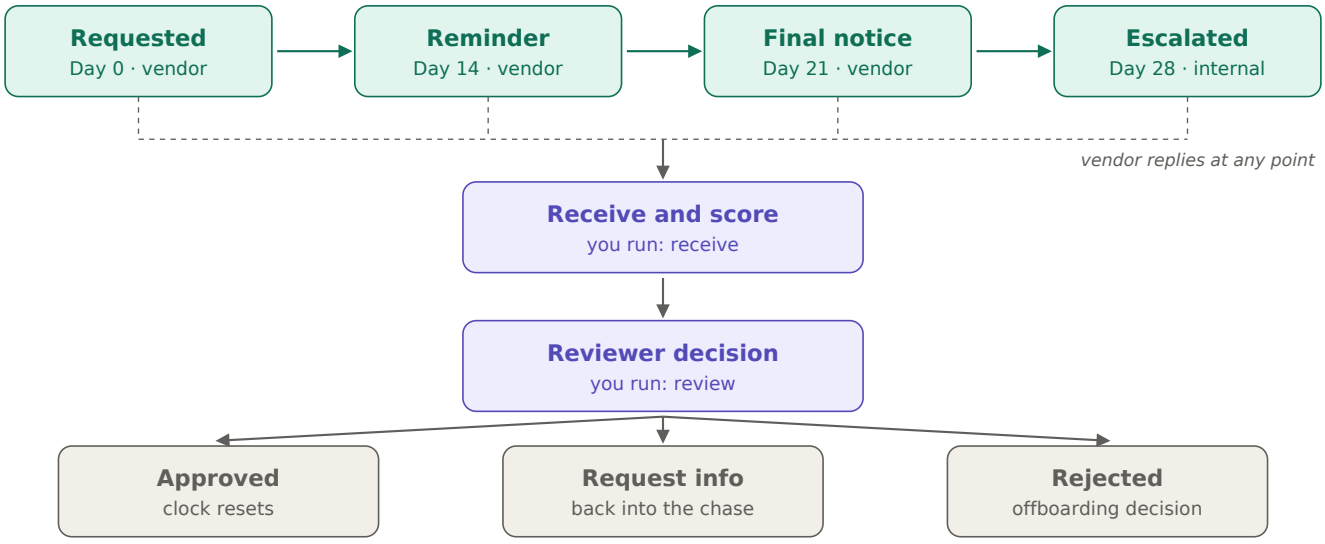
How the TPRM process works

What happens when, who is involved, and how the job runs and sends email by itself

The process on one page

Every vendor moves through the same cycle. The script asks for a security questionnaire before the vendor's reassessment is due, chases politely, escalates internally if the vendor ignores it, then scores whatever comes back. A named person makes the decision. **Only an approval restarts the clock**, so a vendor is never marked as assessed just because an email was sent.



Teal = runs automatically every weekday

Purple = you run one command

Grey = the outcome of the decision

Who does what

The script does this on its own	A person does this
Works out which vendors are due, every weekday	Keeps contact and business-owner emails in the register accurate
Sends requests, reminders and final notices	Saves a returned questionnaire and runs **receive**
Escalates non-responders to your own staff	Reads the review summary and runs **review**
Safety-checks, files, fingerprints and scores responses	Acts on escalations and the Monday digest
Refuses risky approvals without written risk acceptance	Decides whether to accept risk, add conditions or reject
Logs every action in a tamper-evident audit log	

Part 1: How the job runs automatically

The script does not run itself, and it has no timer built in. It does its work in a few seconds and then stops. To make it run every day, you ask your computer's **scheduler** to start it at a set time. Each time it starts it reads the register, checks every vendor against today's date, sends anything that is due, saves the register, writes the log, and exits.

Because every action pushes a deadline forward, running it twice in one day does nothing extra. If a run is missed, the next run simply catches up.

On your Mac: cron

cron is the scheduler built into macOS. Setting it up takes three steps.

1. Find the two paths you need. In Terminal, inside your TPRM folder, run:

```
pwd              # prints your folder path, e.g. /Users/neeco/TPRM_Phase2
which python3    # prints Python's path, e.g. /usr/local/bin/python3
```

2. Open your schedule. Run `crontab -e`. It opens in the vi editor: press `i` to start typing, paste the lines below, replacing the two paths with yours, press `Esc`, then type `:wq` and press Enter to save.

```
# Your two paths from step 1
TPRM=/Users/neeco/TPRM_Phase2
PY=/usr/local/bin/python3

# Weekdays at 7:00am: the daily run
0 7 * * 1-5  cd $TPRM && $PY tprm_assessment_tracker.py run >> cron.log 2>&1

# Mondays at 7:30am: email the security lead the digest
30 7 * * 1   cd $TPRM && $PY tprm_assessment_tracker.py digest >> cron.log 2>&1
```

Reading the 7:00am line left to right: minute 0, hour 7, any day of the month, any month, days 1 to 5 (Monday to Friday). Everything the script prints goes into `cron.log` in your folder, so you can check what happened.

3. Check it's saved. Run `crontab -l` to list your scheduled jobs.

> **Mac gotchas.** (1) If the folder is inside Documents, Desktop or Downloads, macOS privacy controls may silently block cron. Either keep the folder in your home folder (for example /Users/neeco/TPRM_Phase2) or give `/usr/sbin/cron` Full Disk Access in System Settings, Privacy & Security. (2) cron does not run while the Mac is asleep or shut, and missed runs are not repeated. The script catches up at the next run, but emails will be a day late.

For production: an always-on machine

A laptop is fine for testing. For the live process, run it on a machine that is always on, such as a small server or virtual machine managed by IT, using cron on Linux or Task Scheduler on Windows. That also puts it under your normal Essential Eight controls: patching, application control, restricted admin access and centralised logging.

Platform	Scheduler	How
macOS	cron (or launchd)	crontab -e as above. launchd can also catch up on runs missed during sleep.
Linux server	cron	Same crontab lines, using the server's paths.
Windows server	Task Scheduler	Create Basic Task, Daily, weekdays 7:00am. Program: python.exe. Arguments: tprm_assessment_tracker.py run. Start in: the TPRM folder. Select 'Run whether user is logged on or not'.

Part 2: How the emails are sent

The script writes each email itself. It fills in the vendor's name, tier and deadline from the register, attaches the right questionnaire, and then hands the email to your mail server. It reads all of its mail settings from the `.env` file in the same folder, so no passwords live in the code.

Two modes: testing and live

TPRM_EMAIL_MODE	What happens to each email	Use it for
outbox	Saved as a .eml file in the outbox folder. Nothing leaves your computer. Double-click a file to open it in Mail or Outlook.	Testing and checking wording
smtp	Sent for real through your mail server.	Live operation

What happens when a live email is sent

	Step
1	The script connects to the mail server named in TPRM_SMTP_HOST, on TPRM_SMTP_PORT (normally 587).
2	It upgrades the connection to an encrypted one (STARTTLS), so the email and password are not sent in clear text.
3	It logs in as TPRM_SMTP_USER with TPRM_SMTP_PASSWORD.
4	It sends the email from TPRM_SENDER_NAME <TPRM_SENDER_EMAIL>.
5	If sending fails for one vendor, that vendor is logged as failed and left unchanged, so it is retried on the next run. The other vendors still go out.

Who receives what

Email	Sent to	Attachment	When
Assessment request	Vendor contact_email	Full or lite questionnaire	Day 0
Reminder	Vendor contact_email	Questionnaire again	Day 14 if no reply
Final notice	Vendor contact_email	Questionnaire again	Day 21 if no reply
Escalation	Your business_owner_email, cc security lead	None	Day 28, then every 14 days
Further information	Vendor contact_email	None (reviewer's notes in body)	When the reviewer chooses request-info
Digest	Security lead	None	Mondays (or whenever you run it)

Every subject line carries a reference such as **[TPRM-V002]**. Vendors are asked to keep it when they reply, so responses are easy to match to the right vendor. Critical and High vendors receive the full questionnaire; Medium and Low receive the lite one. If the questionnaire file is missing, the email is **not** sent and the failure is logged, rather than sending a request with nothing attached.

> **Before going live on Microsoft 365.** Use a dedicated mailbox (for example tprm@yourorg.com.au) rather than a personal one. Microsoft has been retiring basic username-and-password sign-in for SMTP, so check with your M365 admin that SMTP AUTH is allowed for that mailbox. The longer-term fix is sending through Microsoft Graph with OAuth, which avoids storing a password in .env at all.

Part 3: What happens when, step by step

This follows one Critical vendor through a full cycle. In the example it was last approved on 10 April 2026, so its six-monthly reassessment is due on 9 October 2026. “Day 0” is the day the request goes out.

1 The daily check runs — AUTOMATIC

When	Every weekday at 7:00am, started by the scheduler.
What happens	The script reads the register and looks at every vendor's **status**. The status decides which rule applies: is a reassessment due, has a deadline passed, or is the vendor waiting on us?
Changes	Nothing, unless one of the steps below applies to a vendor.

2 The vendor falls due: request sent (Day 0) — AUTOMATIC

When	The first run on which the vendor's due date is 30 days away or less. In the example: 9 September 2026, 30 days before 9 October.
How it's worked out	Last assessment date plus 182 days (Critical, High) or 365 days (Medium, Low). A vendor with no assessment date is treated as due immediately.
What happens	The vendor is emailed the questionnaire with a 14-day deadline.
Status	Not Due → **Requested**. Request date and response deadline are written to the register.

3 No reply by the deadline: reminder (Day 14) — AUTOMATIC

When	The first run on or after the response deadline, if no response has been received.
What happens	A firmer reminder goes to the vendor with the questionnaire re-attached, and a new 7-day deadline.
Status	Requested → **Reminder Sent**.

4 Still no reply: final notice (Day 21) — AUTOMATIC

When	The first run on or after the new deadline.
What happens	A final notice warns the vendor that the matter will be escalated internally and may affect the relationship. Another 7-day deadline is set.
Status	Reminder Sent → **Final Notice Sent**.

5 Still no reply: internal escalation (Day 28) — AUTOMATIC

When	The first run on or after the final-notice deadline.
What happens	The vendor is not emailed again. Instead, the business owner of the relationship is emailed, with the security lead copied, asking them to chase the vendor and decide whether to accept the risk, restrict access or exit. If no business owner is recorded, it goes to the security lead.
Repeats	Every 14 days (Day 42, Day 56 and so on) until the vendor responds.
Status	Final Notice Sent → **Escalated**.

6 The vendor replies: receive the questionnaire

YOU RUN A COMMAND

When	Whenever the completed questionnaire arrives, at any point in steps 2 to 5.
What you do	Save the attachment anywhere, then run: `python3 tprm_assessment_tracker.py receive --vendor V001 --file ~/Downloads/response.xlsx`
Safety check	The file is refused if it isn't a plain .xlsx, is over 10 MB, contains macros, or links to other workbooks. A refused file is logged and never enters the evidence folder.
Filing	The file is copied into `evidence/V001/<date>/` and given a SHA-256 fingerprint, so you can later prove it hasn't been altered. Earlier files are never overwritten.
Status	Any awaiting status → **Under Review**. The chasers stop.

7 The response is scored

AUTOMATIC

When	Immediately, as part of the receive command.
What happens	Answers are read by matching the question text, then checked against 11 rules covering certification, pen testing, encryption, MFA, data location, access reviews, security function, incidents, breach notification, business continuity and subprocessors. Questions not in the lite version are left out of the score rather than counted as zero.
Knockouts	Encryption not in place, MFA not enforced, or Defence-related data held offshore are **Critical**. Any Critical finding forces a High rating whatever the score.
Output	A score out of 100, a Low, Medium or High rating, a recommendation, and a review summary saved next to the file, listing every finding with its ISO 27001 control reference.

8 A reviewer decides

HUMAN DECISION

When	Within 10 days of the response arriving. After that it appears in the Monday digest as overdue.
What you do	Read the review summary, then run `review` with one of four decisions and your name, for example: `python3 tprm_assessment_tracker.py review --vendor V001 --decision approve --reviewer "Priya Nair"`
Guardrails	Rejecting or requesting information needs notes. Conditional approval needs the conditions and a due date. **A response with Critical findings cannot be approved** unless you add a written risk acceptance, which is recorded permanently.
Outcomes	**approve** or **approve-with-conditions**: go to step 9. **request-info**: the vendor is emailed your notes and goes back to step 2 with a 7-day deadline. **reject**: automation stops and the vendor is flagged for an offboarding decision.

9 The clock resets

AUTOMATIC

When	The moment an approval is recorded.
What happens	The last assessment date becomes today. This is the **only** action that resets it. The decision is also added to the review summary in the evidence folder.
Next cycle	Six months later for Critical and High, twelve for Medium and Low, the cycle starts again at step 2.
Status	Under Review → **Approved** or **Approved with Conditions**.

10 Monday digest

AUTOMATIC

When	Mondays, from the second scheduled line.
What happens	The security lead gets one email listing everything needing attention: escalated vendors, responses waiting too long for review, overdue reassessments, overdue conditions, rejected vendors and vendors with no business owner.

11 The audit trail, throughout

AUTOMATIC

When	Every time any command runs.
What happens	Each action is written to `tprm_audit_log.csv` with the time, the user, the vendor, the status before and after, and the reason. Each row carries a fingerprint linked to the row before, so any later edit or deletion is detected by `verify-log`.

Part 4: Quick reference

The timeline at a glance

Day	What happens	Who is emailed	Status afterwards
-30	Reassessment comes within 30 days of its due date		
0	Assessment request, 14 days to respond	Vendor	Requested
14	Reminder, 7 more days	Vendor	Reminder Sent
21	Final notice, 7 more days	Vendor	Final Notice Sent
28	Escalation	Business owner, cc security lead	Escalated
42, 56 ...	Repeat escalation every 14 days	Business owner, cc security lead	Escalated
Any day	Vendor replies; you run receive	Nobody	Under Review
+10 days	Unreviewed response appears in the digest	Security lead (Mondays)	Under Review
Decision	You run review	Vendor, only for request-info	Approved / Conditions / Rejected / Requested

Commands

Command	What it does	Changes anything?
run --dry-run	Shows what today's run would do	No
run	The daily job (the scheduler runs this)	Yes
status	Table of every vendor and anything needing attention	No
receive	Checks, files, fingerprints and scores a returned questionnaire	Yes
review	Records a named reviewer's decision	Yes
digest	Emails the security lead the attention list	Sends one email
verify-log	Checks the audit log hasn't been altered	No

Add `--as-of-date YYYY-MM-DD` to run, status, receive or review to simulate a different day.

Statuses

Status	Meaning	Ball is with
Not Due	Assessed recently enough; nothing to do yet	Nobody
Requested / Reminder Sent / Final Notice Sent	Questionnaire is out; being chased	Vendor
Escalated	Vendor has ignored three emails	Business owner
Under Review / Received (Manual Review)	Response received and scored (or unscoreable)	Reviewer
Approved / Approved with Conditions	Assessment complete; clock reset	Nobody (or vendor, for conditions)
Rejected	Vendor failed review	Business owner (offboarding)

Changing the timings

All timings are settings near the top of `tprm_assessment_tracker.py`. Change a number, save the file, and the next run uses it.

Setting	Default	Controls
TIER_REASSESSMENT_FREQUENCY_DAYS	182 / 182 / 365 / 365	How often each tier (Critical / High / Medium / Low) is reassessed
--lookahead-days (command option)	30	How early the request goes out before the due date
RESPONSE_DEADLINE_DAYS	14	Time to respond to the first request
REMINDER_DEADLINE_DAYS	7	Time added by each reminder and the final notice
ESCALATION_REPEAT_DAYS	14	How often escalations repeat
REVIEW_SLA_DAYS	10	How long a response can wait before it's flagged
INFO_REQUEST_DEADLINE_DAYS	7	Time given after a request-info decision